

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 — OWASP Dependency-Check + Maven · Generated: 2026-06-13 · SHA: `61ed8c3`

Summary

Metric	Count
Dependencies scanned	10
Total CVEs found	75
CRITICAL CVEs	16
HIGH CVEs	46
MEDIUM CVEs	12
LOW CVEs	1
Outdated dependencies	9
License violations	2
Supply-chain alerts	2

Supply-Chain Alerts

CRITICAL — Typosquatted dependency detected. `com.fastxml.jackson.core:jackson-databind:2.9.8` — groupId `com.fastxml` impersonates the legitimate `com.fasterxml.jackson.core` (missing the characters `er`). This coordinate does **not exist on Maven Central** and caused a build resolution failure. A typosquatted package may contain malicious code. **Remove immediately** and do not allow this coordinate into any build.

HIGH — Untrusted HTTP repository declared. Repository `internal-untrusted-mirror` at `http://insecure-mirror.example.net/maven2` is served over **plain HTTP**. Artifacts fetched from unencrypted repositories are susceptible to man-in-the-middle (MitM) injection. Maven's default HTTP mirror blocker already rejects this repository. Remove this `<repository>` block from `pom.xml` and use only HTTPS-authenticated sources (Maven Central or a verified internal proxy).

Known-Vulnerable Dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix Version
<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.15.0
<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.9.9.1
<code>mysql:mysql-connector-java</code>	8.0.30	CVE-2023-22102	8.3	HIGH	8.1.1

com.google.protobuf:protobuf-java	3.19.4	CVE-2024-7254	7.5	HIGH	3.25.5
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2.25.4
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	32.0.0-jre
com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	MEDIUM	2.9.8
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.7
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.18.0

All CVEs — CRITICAL

CVE	Dependency	CVSS	Description	Fix
CVE-2021-44228	log4j-core:2.14.1	10.0	CRITICAL — Log4Shell RCE via JNDI lookup	2.15.0
CVE-2021-45046	log4j-core:2.14.1	9.0	CRITICAL — Incomplete Log4Shell fix; RCE in non-default config	2.16.0
CVE-2019-14379	jackson-databind:2.9.8	9.8	CRITICAL — RCE via SubTypeValidator gadget deserialization	2.9.9.1
CVE-2019-14540	jackson-databind:2.9.8	9.8	CRITICAL — RCE via c3p0 gadget chain	2.9.10
CVE-2019-14892	jackson-databind:2.9.8	9.8	CRITICAL — RCE via commons-configuration gadget	2.9.10
CVE-2019-14893	jackson-databind:2.9.8	9.8	CRITICAL — RCE via xalan gadget	2.9.10
CVE-2019-16335	jackson-databind:2.9.8	9.8	CRITICAL — RCE via netty-handler gadget	2.9.10
CVE-2019-16942	jackson-databind:2.9.8	9.8	CRITICAL — RCE via commons-dbcp gadget	2.9.10.1
CVE-2019-16943	jackson-databind:2.9.8	9.8	CRITICAL — RCE via p6spy gadget	2.9.10.1
CVE-2019-17267	jackson-databind:2.9.8	9.8	CRITICAL — RCE via xnio gadget	2.9.10
CVE-2019-17531	jackson-databind:2.9.8	9.8	CRITICAL — RCE via logback-core gadget	2.9.10.1
CVE-2019-20330	jackson-databind:2.9.8	9.8	CRITICAL — RCE via net.sf.ehcache gadget	2.9.10.2
CVE-2020-8840	jackson-databind:2.9.8	9.8	CRITICAL — RCE via xbean-reflect gadget	2.9.10.3
CVE-2020-9546	jackson-databind:2.9.8	9.8	CRITICAL — RCE via shiro-core gadget	2.9.10.3
CVE-2020-9547	jackson-databind:2.9.8	9.8	CRITICAL — RCE via ibatis-sqlmap gadget	2.9.10.3
CVE-2020-9548	jackson-databind:2.9.8	9.8	CRITICAL — RCE via anteros-core gadget	2.9.10.3

All CVEs — HIGH (46 total, representative sample)

CVE	Dependency	CVSS	Description	Fix
CVE-2020-10672	jackson-databind:2.9.8	8.8	HIGH — RCE via ehcache gadget	2.9.10.3
CVE-2020-10673	jackson-databind:2.9.8	8.8	HIGH — RCE via ignite-jta gadget	2.9.10.3
CVE-2020-10968	jackson-databind:2.9.8	8.8	HIGH — RCE via openjpa gadget	2.9.10.4
CVE-2020-10969	jackson-databind:2.9.8	8.8	HIGH — RCE via jndi gadget	2.9.10.4
CVE-2020-11111	jackson-databind:2.9.8	8.8	HIGH — RCE via ariesframework gadget	2.9.10.4
CVE-2020-11112	jackson-databind:2.9.8	8.8	HIGH — RCE via druid gadget	2.9.10.4

CVE-2020-11113	jackson-databind:2.9.8	8.8	HIGH	— RCE via openjpa-lib gadget	2.9.10.4
CVE-2020-10650	jackson-databind:2.9.8	8.1	HIGH	— RCE via RMI lazy deserialization	2.9.10.3
CVE-2020-36179–36189	jackson-databind:2.9.8	8.1	HIGH	— RCE via multiple gadget chains (11 CVEs)	2.12.1
CVE-2021-20190	jackson-databind:2.9.8	8.1	HIGH	— RCE via JEditorPane gadget	2.12.1
CVE-2019-12086	jackson-databind:2.9.8	7.5	HIGH	— SSRF via HikariCP gadget	2.9.9
CVE-2020-36518	jackson-databind:2.9.8	7.5	HIGH	— DoS via unbounded memory allocation	2.13.2.1
CVE-2022-42003	jackson-databind:2.9.8	7.5	HIGH	— DoS via deeply nested arrays	2.13.4.2
CVE-2022-42004	jackson-databind:2.9.8	7.5	HIGH	— DoS via OBJECT_AND_ARRAY_CREATION feature	2.13.4.2
CVE-2023-22102	mysql-connector-java:8.0.30	8.3	HIGH	— MitM downgrade via malicious server handshake	8.1.1
CVE-2026-34479	log4j-core/api:2.14.1	7.5	HIGH	— SSRF / info disclosure via lookup pattern	2.25.4
CVE-2026-34480	log4j-core:2.14.1	7.5	HIGH	— Thread-context map security bypass	2.25.4
CVE-2023-2976	guava:24.1.1-jre	7.1	HIGH	— Temp dir race condition / privilege escalation	32.0.0-jre
CVE-2024-7254	protobuf-java:3.19.4	7.5	HIGH	— Unbounded recursion DoS during parsing	3.25.5
CVE-2022-3171	protobuf-java:3.19.4	7.5	HIGH	— CPU DoS via crafted protobuf input	3.19.6
CVE-2022-3509	protobuf-java:3.19.4	7.5	HIGH	— CPU DoS via crafted text-format message	3.19.6
CVE-2022-3510	protobuf-java:3.19.4	7.5	HIGH	— CPU DoS via crafted binary-format message	3.19.6

All CVEs — MEDIUM

CVE	Dependency	CVSS	Description	Fix
CVE-2021-44832	log4j-core:2.14.1	6.6	MEDIUM — RCE via JDBC appender (attacker controls config)	2.17.1
CVE-2026-34477	log4j-core/api:2.14.1	5.9	MEDIUM — Log injection via thread context map	2.25.4
CVE-2021-45105	log4j-core:2.14.1	5.9	MEDIUM — Infinite recursion DoS via self-referential lookup	2.17.0
CVE-2025-68161	log4j-core:2.14.1	4.8	MEDIUM — Information leak via pattern layout	2.25.4
CVE-2019-12384	jackson-databind:2.9.8	5.9	MEDIUM — SSRF via server-side request forgery gadget	2.9.9.1
CVE-2019-12814	jackson-databind:2.9.8	5.9	MEDIUM — XXE via com.github.mbechler gadget	2.9.10
CVE-2023-35116	jackson-databind:2.9.8	4.7	MEDIUM — Stack overflow DoS via deeply nested Map/List	2.15.0
CVE-2018-1000873	jackson-annotations:2.9.0	6.5	MEDIUM — Deserialization issue in Java 8 date/time modules	2.9.8
CVE-2021-29425	commons-io:2.4	4.8	MEDIUM — Relative path traversal in FileNameUtils	2.7
CVE-2024-47554	commons-io:2.4	4.3	MEDIUM — Uncontrolled resource consumption in XmlStreamReader	2.14.0
CVE-2025-48924	commons-lang3:3.4	5.3	MEDIUM — Uncontrolled resource consumption via Streams.of()	3.18.0

All CVEs — LOW

CVE	Dependency	CVSS	Description	Fix
CVE-2020-8908	guava:24.1.1-jre	3.3	LOW — Insecure temp directory creation (local info disclosure)	32.0.0-jre

Outdated Dependencies

Dependency	Current	Latest	Update Type
org.apache.logging.log4j:log4j-core	2.14.1	2.24.3	minor
org.apache.logging.log4j:log4j-api	2.14.1	2.24.3	minor
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.18.3	minor
com.google.guava:guava	24.1.1-jre	33.4.0-jre	major
commons-io:commons-io	2.4	2.18.0	minor
org.apache.commons:commons-lang3	3.4	3.17.0	minor
mysql:mysql-connector-java	8.0.30	8.0.33	patch
com.google.protobuf:protobuf-java	3.19.4	4.29.3	major (transitive via mysql)
com.fasterxml.jackson.core:jackson-annotations	2.9.0	2.18.3	minor (transitive)

License Analysis

Dependency	License	Status
mysql:mysql-connector-java:8.0.30	GPL-2.0 with FOSS exception	VIOLATION
com.fastxml.jackson.core:jackson-databind:2.9.8	UNKNOWN (typosquat — unresolvable)	VIOLATION
org.apache.logging.log4j:*	Apache-2.0	OK
com.fasterxml.jackson.core:*	Apache-2.0	OK
com.google.guava:guava	Apache-2.0	OK
commons-io:commons-io	Apache-2.0	OK
org.apache.commons:commons-lang3	Apache-2.0	OK
com.google.protobuf:protobuf-java	BSD-3-Clause	OK
org.junit.jupiter:*	EPL-2.0	OK

Note: `mysql-connector-java` is licensed GPL-2.0 with FOSS classpath exception. Including this in a proprietary distribution may create license compliance obligations. Replace with `com.mysql:mysql-connector-j` (commercial/proprietary) or MariaDB Connector/J (LGPL).